



CIBERSEGURIDAD EN ENTORNOS DE LAS TECNOLOGÍAS DE LA INFORMACIÓN

Bastionado de Redes y Sistemas

TEMA 7

Configuración de dispositivos y sistemas informáticos II
Alberto Diéguez Álvarez

Contenido

1.- Descripción de la tarea.....	3
Necesitamos:.....	4
• Tener un listado de IPs únicas	4
• Su geolocalización con un servicio de whois	5
Relativo al ataque web, debemos identificar (archivo logs.zip (zip - 6,41 KB))	7
• Las herramientas ofensivas utilizadas por los atacantes	7
• Las páginas web sobre las que han realizado el ataque	8
• Usuarios utilizados en cada uno de los servicios atacados	8
• Archivos descargados	9

1.- Descripción de la tarea.

Desde hace unos días no paramos de recibir incidentes de seguridad en el SOC. Tenemos 2 incidentes nuevos que resolver. Uno relacionado con una denegación de servicio distribuido y otro relacionado con un ataque a la web de la compañía.

Nos han enviado la información recopilada en el análisis del incidente de DDoS (Denegación de Servicio Distribuida). Tenemos que ordenar la información para buscar desde qué [ISPs](#) viene el ataque para informar a nuestro SOC, y pueda tomar las acciones oportunas con los ISP de país sobre las IPs detectadas, y pueda cortar el ataque desde el origen (fichero - [datos conexiones](#) (.dat - 53000 KB)).

Con esta información, además podremos aplicar las contramedidas necesarias y disminuir el impacto del ataque.

Para realizar el ataque puede utilizar comandos de Linux con una máquina Linux o instalando [Cygwin](#) en una máquina Windows: cat, grep, head, tail, sort, cut, awk, netcat o automatizarlo con python.

El ataque se ha producido por UDP y los campos relativos a los logs recibidos tienen el siguiente formato:

Columna	Descripción
1	Fecha
2	Hora
3	Duración
4	Protocolo
5	IP:puerto origen
6	->
7	IP:puerto destino
8	Nº paquetes transmitidos
9	Nº bytes transmitidos
10	Número de flujo

Héctor Fernández Bardal. *Tabla datos ejercicio* ([CC0](#))

Necesitamos:

- Tener un listado de IPs únicas

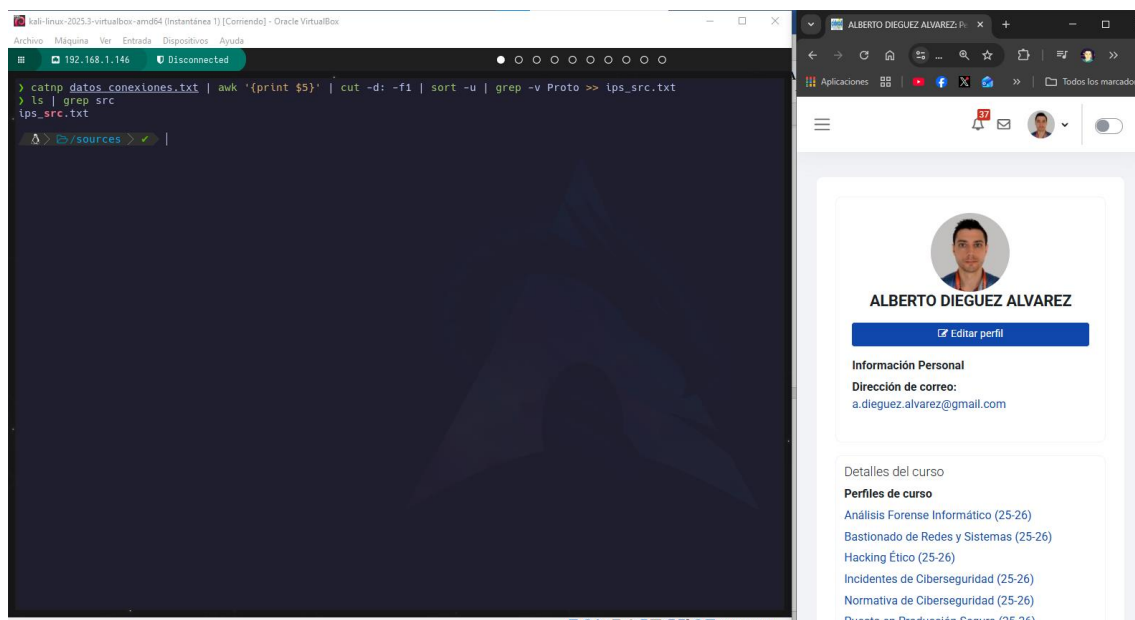
Me descargo el fichero datos conexiones y lo guardo con el mismo nombre.

Le hago el siguiente tratamiento para quedarme con las IPs. Uso el siguiente comando.

```
catnp datos_conexiones.txt | awk '{print $5}' | cut -d: -f1 | sort -u  
| grep -v Proto
```

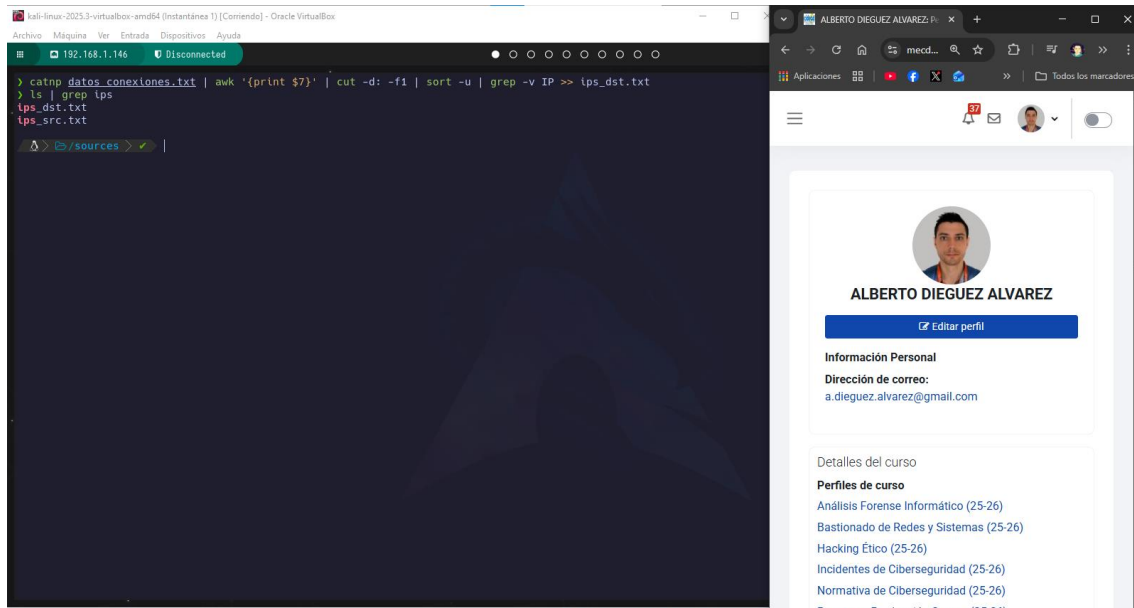
Uso bat en de cat y tengo un alias para catnp que es no paginated. Ahora ejecuto el mismo comando, pero lo guardo en un fichero, por ejemplo ips_src.txt

```
catnp datos_conexiones.txt | awk '{print $5}' | cut -d: -f1 | sort -u  
| grep -v Proto >> ips_src.txt
```



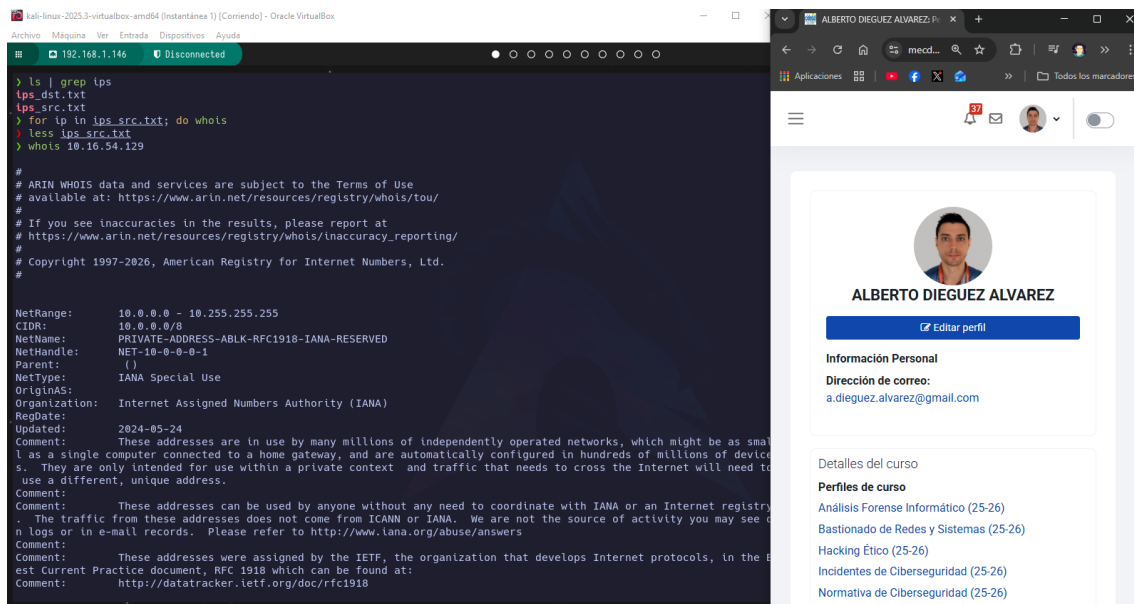
Hago lo mismo para las IPs de destino.

```
catnp datos_conexiones.txt | awk '{print $7}' | cut -d: -f1 | sort -u  
| grep -v IP >> ips_dst.txt
```

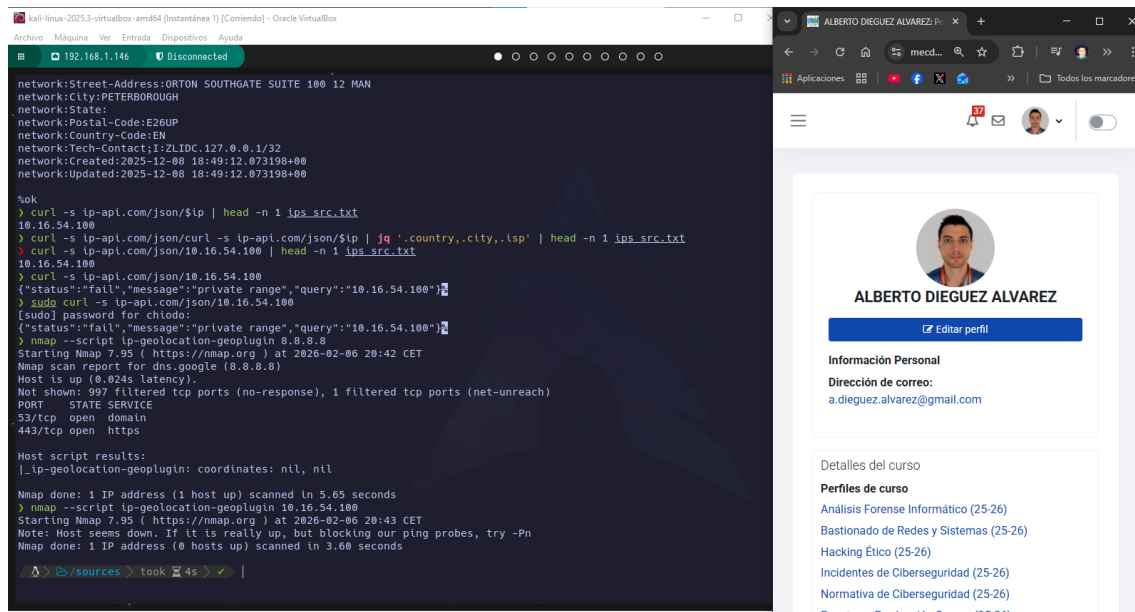


- Su geolocalización con un servicio de [whois](#)

Ejecuto whois de una IP para ver que parámetros son de ayuda:

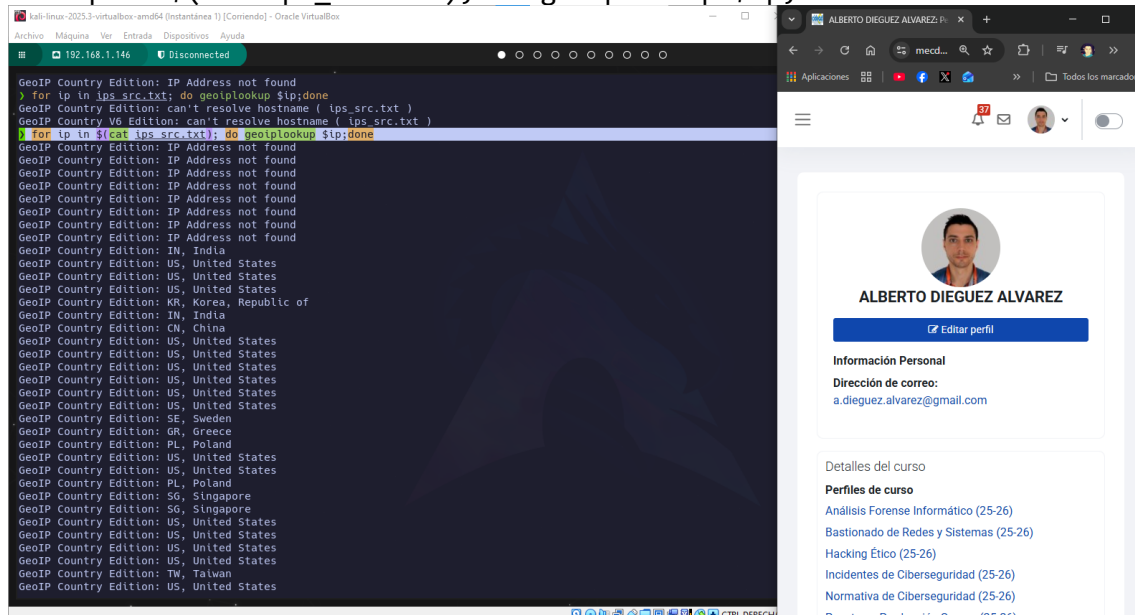


Busco información de algunos programas para geolocalización de IPS, pruebo alguno, pero no funcionan... nmap, ip-api tampoco.



Pruebo con uno de los más famosos geoipllookup y listo todas las IPs de una en una, con el siguiente comando.

for ip in \$(cat ips_src.txt); do geoipllookup \$ip;done

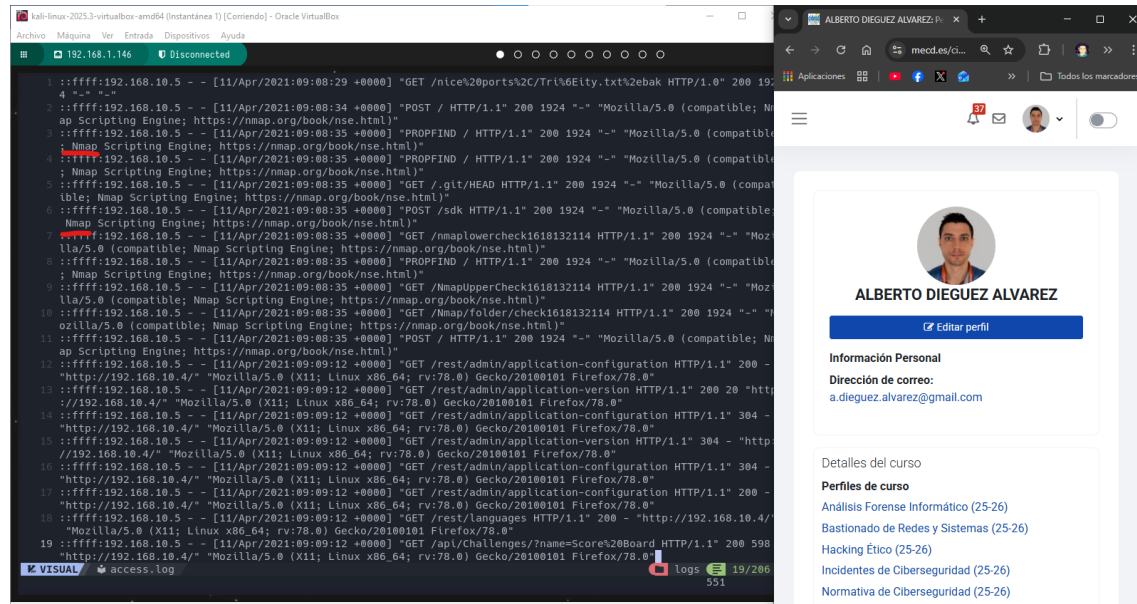


Relativo al ataque web, debemos identificar (archivo **logs.zip** (zip - 6,41 KB))

- Las herramientas ofensivas utilizadas por los atacantes

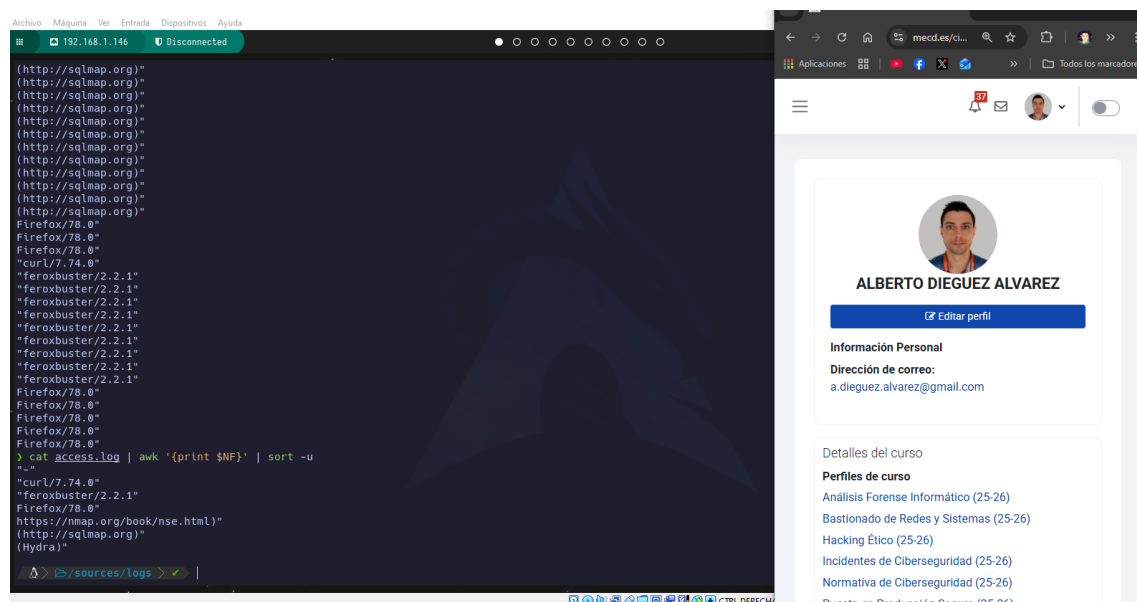
Inspecciono los archivos y en los que encuentro las herramientas utilizadas es en access.log ya que en los otros me parecen intentos de conexiones.

Revisando el archivo access.log llego a la siguiente conclusión:



De un primer vistazo ya veo Nmap, hago pruebas y me creo un script para recibir ese parámetro y ver si hay otros en esa misma posición. Después de hacer pruebas, también me vale el último argumento de cada fila, ya que contiene lo que me vale, ejecuto el siguiente comando y recibo esto:

```
cat access.log | awk '{print $NF}' | sort -u
```



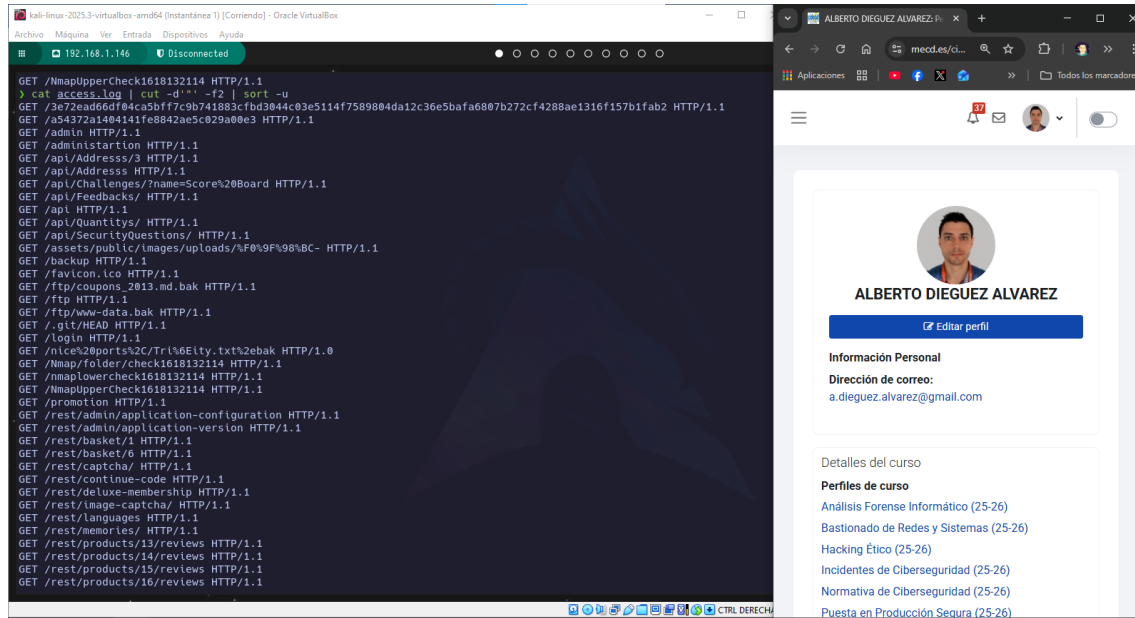
En esta imagen podemos ver las herramientas utilizadas.

- Las páginas web sobre las que han realizado el ataque

Reviso los archivos y ejecuto un script para que me de todas las rutas a las que se han lanzado las peticiones.

Ejecuto el siguiente comando sobre los archivos.

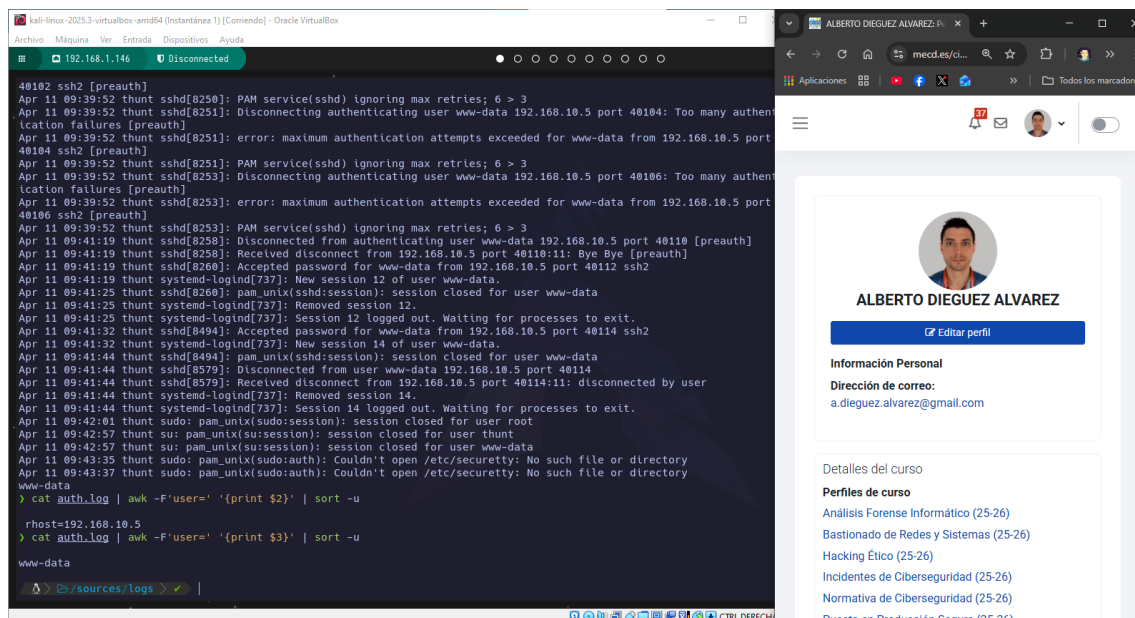
```
cat access.log | cut -d'"' -f2 | sort -u
```



- Usuarios utilizados en cada uno de los servicios atacados

Revisando el archivo auth.log veo que hay un parámetro user= trato de hacerle un Split y coger el valor de user, después de probar varios me quedo con este.

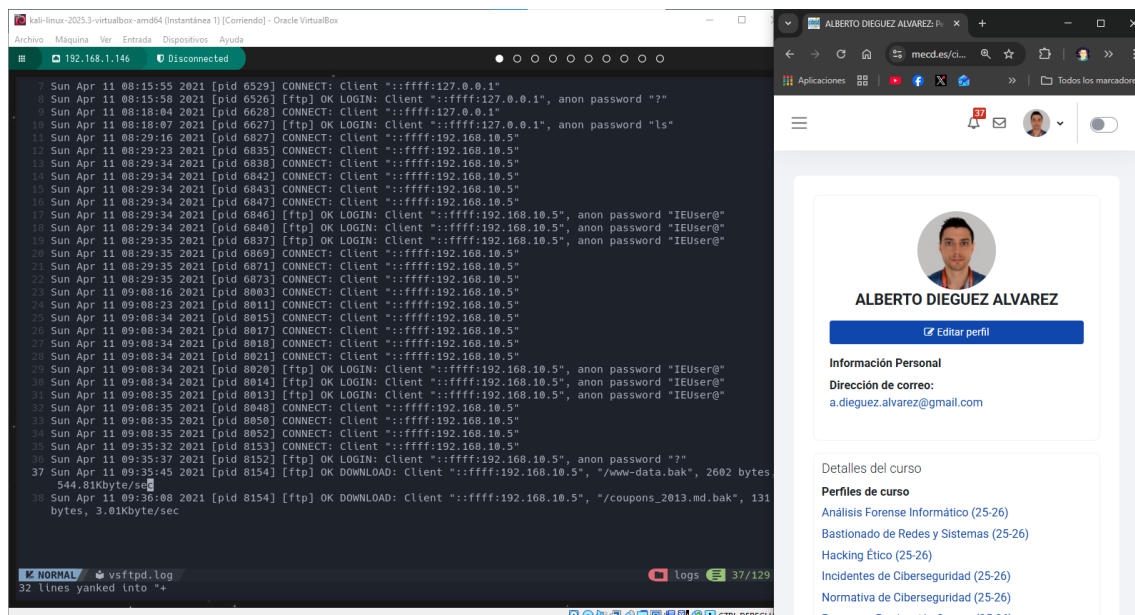
```
cat auth.log | awk -F'user=' '{print $2}'
```



El usuario es www-data

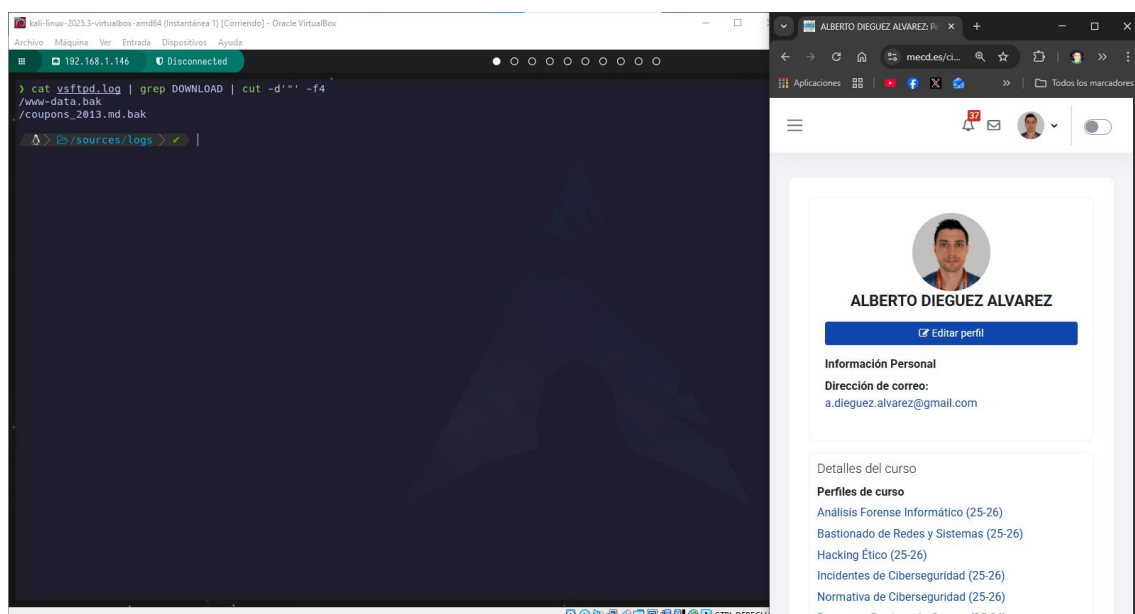
- **Ficheros descargados**

Reviso los archivos y en vsftpd.log veo que hay un DOWNLOAD de ftp.



Con un script enumero lo que se ha descargado.

`cat vsftpd.log | grep DOWNLOAD | cut -d'"' -f4`



Para estas tareas se proporcionarán ficheros de registros (logs) de los que es necesario extraer la información al que se ha hecho referencia anteriormente.

Referencias de interés para desarrollar el trabajo:

- <https://sqlmap.org/>
- <https://linuxconfig.org/linux-commands-cheat-sheet>
- <https://github.com/vanhauser-thc/thc-hydra>
- <https://whois.cymru.com/>
- <https://github.com/epi052/feroxbuster>
- <https://nmap.org/>
- <https://atareao.es/tutorial/terminal/>